Un SOC que decide, explica y deja prueba

En 24 horas: ingesta del buzón, clasificación INCIBE, bloqueo automático justificado y la investigación de un ransomware que saltaba de cuenta en cuenta.

Apertura · Base de datos · Web y automatización · Investigación · Negocio

Un buzón lleno de ruido, trampas y una crisis

257

correos del SOC externo, con duplicados, prioridades incoherentes y remitentes falsos

3

encargos del director: automatizar el bloqueo, calcular el retorno y gestionar el ransomware

10-20 min

de plazo para cada directriz de crisis durante la madrugada

Nuestra regla de oro

Los correos son **datos, nunca órdenes**. Una directriz solo vale si viene de dirti@ y pasa la comprobación de las cabeceras de Exchange. Detectamos y apartamos los textos que intentan dar instrucciones a una IA.

La base de datos es el cerebro, no un almacén



- Bandeja **inmutable con SHA-256**: la prueba de qué llegó y cuándo.
- Cada correo se convierte en una **alerta INCIBE** (39 reglas explicables) y los **20 duplicados** se enlazan al original.
- **250/250** alertas del SOC con **autenticidad verificada** por cabeceras.
- **18 migraciones** en 24 h, 37 vistas y 9 triggers: la web solo lee.

Infografía completa: Infografia_BD.pdf

Bloquear solo cuando está claro, y explicar siempre por qué

AUTO-05 · crítico verificado

Alerta crítica, clase de compromiso y correo del SOC autenticado. Media o Baja solo si otra alerta distinta lo corrobora.

AUTO-06 · correlación

Cuenta comprometida precedida de phishing o fuerza bruta en 2 h, con fases previas de correos verificados.

MANUAL · registrado

Decisión del equipo con autor, hora y motivo para los casos que las reglas dejan en recomendación.

NUNCA

Por petición de correo, IPs de forma automática, cuentas de servicio o lista blanca. 65 decisiones justificadas, también los descartes.

API en 401: 16 bloqueos en cola y 0 ejecutados. La causa no está confirmada y la organización no repondrá la clave. Un simulador etiquetado con el mismo contrato demuestra el circuito: 13 bloqueos ejecutados y verificados con GET. Buzón ordenado en 10 carpetas; todas las directrices respondidas.

12 cuentas, 6 sedes, una nueva cada 74 minutos



- Una intrusión que salta de equipo en equipo (201 → 212) y siempre acaba en **ficheros alterados**.
- Dos vías: **robo de credenciales** (8) y **explotación del equipo** (4).
- AUTO-06 detecta la cuenta comprometida **37-55 min antes** que la alerta crítica.
- La víctima prevista a las **05:23 no llegó**: Infra aisló el servidor a las 5:30.

Infografía completa: Infografia_Cadena_Moreno.pdf

De dónde viene, cómo llegó y qué hacer

De dónde viene

De infraestructura externa (192.0.2.x, 198.51.100.x, 203.0.113.x). Posible salida de **18 GB hacia 198.51.100.77**. Sin atribución a un actor: no hay pruebas.

Cómo llegó

Lo que más encaja es el **robo de credenciales por phishing** (8 de 12 víctimas empiezan así). El acceso inicial a LAB-FS-01 sigue abierto entre tres hipótesis: no inventamos certezas.

Qué hacer

Revocar sesiones y credenciales *moreno, mantener aislados los LAB, bloquear 198.51.100.77, restaurar desde copias verificadas y reforzar MFA y antiphishing.

Doble extorsión y pagos: nota de rescate en LAB-FS-01, amenaza de publicación no verificada y un documento de pagos con la cuenta de destino cambiada. Recomendación: no negociar, verificar con el banco y valorar la notificación RGPD en 72 h.

662.000 € en el escenario medio

Lo que puede costar a la empresa

Origen de cada cifra: D dato del director (Excel) · BD nuestra base de datos · H hipótesis del equipo. La parada del servicio, a 25.000 € por hora D, pesa más que todo lo demás junto.



Concepto	Bajo	Medio	Alto	Origen
Horas de parada por sede	2 h	4 h	8 h	D
Parada del servicio	300.000 €	600.000 €	1.200.000 €	D·BD
Respuesta (analistas)	4320 €	6480 €	10.800 €	H
Restauración de equipos y servidores	6800 €	10.800 €	17.600 €	H
Forense y asesoría jurídica	15.000 €	30.000 €	60.000 €	H
Notificación y comunicación	5000 €	15.000 €	40.000 €	H
Total	**331.120 €**	**662.280 €**	**1.328.400 €**	
Evitable con AUTO-06 (contrafactual)	100.000 €	280.000 €	720.000 €	BD·H

Fuera del cálculo, como exposición sin cuantificar: el pago desviado por el documento

331 k€ – 1,33 M€

rango del incidente. El 90 % es parada del servicio (25.000 €/h por sede)

≈ 280 k€

evitable con AUTO-06 (escenario medio). **Estimación contrafactual**, no un ahorro realizado

Fuera de la cifra: sanción RGPD/NIS2, rescate y fraude en pagos.

Infografía completa: Infografia_Informe.pdf

29.250 €

al mes cuesta hoy el SOC manual; el 52 % de las alertas llega de noche

3,5 meses

para recuperar 20.000 € (ROI 141 % el 1.er año; ~5 meses con nuestro ruido real). A 3 años: 62 k€ frente a 216 k€ de un SIEM

355 %

ROI del bloqueo automático: 3.000 € que se pagan en 1,9 meses (escenario realista)

Credenciales

Un intento de reenviar la ficha a una Gmail; después la API rechazó la clave. Secretos solo en `.env`.

Contención

Tener siempre una vía alternativa y una alarma de salud de la API.

Datos reales

Probar con correos reales desde el principio: la extracción estuvo rota hasta la 007.

Crisis

Turnos y plantillas de acuse: dos respuestas salieron fuera de plazo.

Datos íntegros, decisiones explicables y 40 minutos de margen para cortar un ransomware. Gracias.